CST8919 DevOps Security

Complete study notes | Modules 7–14

One organized study guide based on the course pages. It retains lesson explanations, examples, key terms, and references. Self-checks, learning activities, labs, quizzes, assignments, and exams are omitted.

Contents

Module 7. Classifying security needs and injury
Module 8. Security policies and acceptable use
Module 9. Security principles
Module 10. Access controls
Module 11. Identification and authentication
Module 12. Incident handling and resilience
Module 13. Cloud security outlook
Module 14. Final exam

Module 14 contains only the final exam in the course contents. It is listed here for completeness and excluded from these notes.

Module 7 | Classifying security needs and injury

Security requirements should reflect the harm that a breach could cause. This module introduces injury testing and formal security categorizations, including separate assessments of confidentiality, integrity, and availability. It compares common labels and guidance from NIST, the Government of Canada, and cloud programs.

Introduction

After having explored and analyzed the basic attributes of information security: confidentiality, integrity, and availability, you will now study the terminology used in the cloud industry to formally communicate security requirements for information system solutions, including in cloud computing infrastructure.

Learning Objectives

By the end of this module, you should be able to complete the following:

1. Recall the terminology associated with security labels.
2. Define the considerations that justify higher security requirements.

Key Terms and Concepts

Cabinet confidences — The Canadian government is based on a Cabinet system. Consisting of ministers acting in the name of the Queen's Privy Council for Canada, Cabinet establishes the federal government's policies and priorities for the country. Cabinet ministers are collectively responsible for all actions taken by the Cabinet and must publicly support all Cabinet decisions. In order to reach final decisions, ministers must be able to express their views freely during the discussions held in Cabinet. To allow the exchange of views to be disclosed publicly would result in the erosion of the collective responsibility of ministers. As a result, the collective decision-making process has traditionally been protected by the rule of confidentiality, which upholds the principle of collective responsibility and enables ministers to engage in full and frank discussions necessary for the effective functioning of a Cabinet system. The Supreme Court of Canada has recognized that Cabinet confidentiality is essential to good government. In the decision Babcock v. Canada (Attorney General), 2002 SCC 57 at paragraph 18, the Court explained the reasons for this: "The process of democratic governance works best when Cabinet members charged with government policy and decision-making are free to express themselves around the Cabinet table unreservedly."

Need for a formalized categorization

We can understand the need for a formalizing system that categorizes security requirements in a way that everybody understands and agrees upon. After all, to the person in charge of a system, that system will always be considered important, or critical, or however else that person would choose to describe. In order for different groups to interact and understand correctly the needs for security, a standardized categorization system needs to be put in place.

In this module, you will explore different approaches to this categorization effort and the systems that have emerged from this. It will lean heavily on the notions of confidentiality, integrity, and availability since those are the attributes that are used to define the security requirement in the first place.

Injury test

The starting point to understand security categorization is to understand the notion of injury. For instance, confidentiality is defined as “only allowing authorized individuals to see the information”. That’s straight-forward. The injury test is then applied by asking what could happen if confidentiality is breached? This is asking two different questions:

1. What is the degree of injury that could reasonably be expected to be sustained if there is a breach of confidentiality?
2. Who would suffer that injury?

For example, if your account in an online shopping store is breached, what is the injury that could be sustained? When asking that question, we turn to facts about the data in the account to answer the question, which is exactly what we should do. The store might say, “that would be bad”, or “that would not be good for business”, but that is of little to no value. Look back at the two questions. If the account holds your full name, address, and date of birth, there could be a threat to identity theft. If it holds your social insurance number as well, then identity theft is a distinct possibility. If the account has your credit card information, then you could be subjected to fraud. If the account holds very personal and private information, there could be risk of blackmail, coercion, or other injury.

The Ashley Madison security breach provides a clear example of private and personal data being exposed with dire consequences.

We are getting closer to being able to understand the notion of injury that could be sustained from a confidentiality breach. The next question is “who would suffer that injury?”. The answer might appear obvious, since the customer of the online service is the one suffering the injury, but we must consider other aspects of a potential breach.

As you know, breaches do not typically affect only one person at a time. Data breaches routinely impact millions of customers. Each customer can potentially suffer a personal injury, but what about the organization? It stands to lose a tremendous amount of money dealing with the incident, it will lose productivity, its reputation will be impacted, and it may never recover from the attack. Not to mention that it might suffer lawsuits from the impacted customers.

The injury test is not easy to conduct, but it brings forth important questions about the potential ramifications of security threats.

Protected and classified

As to the question of “who suffers the injury?”, the typical distinction that is applied for matters of security is the following:

- The injury is sustained by a private individual, or a private organization, defined as “non-national interests”
- The injury is suffered by the country, defined “national interests”

When the injury is suffered by non-national interests, the information is labelled as “Protected information”. If the information is of national interest, then it is labelled as “classified information”. Within these categories, there are specific labels to the level of injury that could be sustained. We will explore these categories in detail in the next sections.

Security labels for PROTECTED information

Unfortunately, security labels can be difficult to determine, and even experts struggle in certain situations to determine the proper labelling for some information. Let’s have a look at the different labels that can be applied to information and systems.

First, the easy part. If there is no significant injury that could be expected from the disclosure of information, whether to national or non-national interests, that information is labelled as UNCLASSIFIED. The term is misleading because it suggests that the information has not been categorized or labelled, but it actually means that the level of injury sustained has been deemed insignificant. Publicly available information will always be UNCLASSIFIED, but not all UNCLASSIFIED information is public. Information that is meant for internal use, like a luncheon meeting, a memo about cleaning after yourself in the cafeteria, etc. is not meant for public distribution, but there would not be any foreseeable injury from its disclosure to external people.

In the protected realm, there are three categories: Protected A, Protected B, and Protected C. Protected A means that it is possible that it will cause injury. This could be an address by itself, or a phone number by itself, even a social insurance number without any other identity information could still not reasonably be seen to cause injury. Protected B information is associated with “a serious” or “a grave” injury. This is closer to the example we used previously. If it can cause fraud or identity theft, the information is typically Protected B. Health and financial information are typically under this label. So would be any private information such as political opinions, ethnicity, religious beliefs, sexual orientation, and much more. Protected C is defined as potentially causing “an exceptionally grave injury”. Not many people have information about them that if disclosed to unauthorized individuals could cause exceptionally grave injury. This is seen for police informants, witness protection, undercover operatives, and other similar situations.

This infographic is used by the Department of National Defence (DND) to help individuals to apply the injury test to information.

For more details on the injury test and how it is applied, consult the following reference (which includes the previous infographic)

Security labels for CLASSIFIED information

When it comes to classified information, i.e., information that pertains to the national interests, there is another set of labels that are used. This is done intentionally so that the label can clearly communicate what type of information it relates to. Some examples of information that is of national interests include:

- Cabinet confidences
- Details of military operations
- Communications between world leaders
- Research and development conducted at national laboratories

For this type of information, the level of injury can be even more complex to establish. The UNCLASSIFIED label is still used for information for which the injury of disclosure is not significant. When there is injury, which could be embarrassing to the nation, or damage the reputation of official national figures, the information is labelled CONFIDENTIAL. When there is a significant injury that could be sustained, often established by the cost associated to damage control and recovery, the label used is SECRET. For cases where the disclosure of information could cause an exceptionally grave injury, the label used is the infamous TOP SECRET.

During World War II, the Allies adopted the designation ULTRA SECRET for information that was obtained by breaking high-level encrypted enemy radio and teleprinter communications. This information was so sensitive that it needed to be recognized beyond the typical designation TOP SECRET. ULTRA is no longer used for information classification.

Beyond confidentiality

You might have noticed that so far, we have only discussed the confidentiality aspect of information. While it is true that the confidentiality rating is often the most important aspect of information security, it is not only the case. Injury assessment should also consider a breach of integrity or a breach of availability.

As we studied in a previous module, a breach of integrity means that the information is altered, incomplete, tampered with, or damaged in some way. Basically, the information is not trustworthy anymore. We also previously studied availability as a basic attribute of information security, which we defined by the capacity to use information systems in a timely manner.

Now, consider the following example of what could happen regarding your bank account. Let’s assume that you have $5000 in your account. How would you feel regarding these three different events:

1. The bank informs you that a clerical error has exposed the funds available in many accounts, including yours (confidentiality breach).
2. The bank informs you that because of a software glitch, your funds will not be available for the next 24 hours (availability breach).
3. The bank does not say anything, however when you connect to your bank account, the remaining funds are $0.00 (integrity breach).

This quick example highlights how the sustained injury can hit differently based on which attribute of the information is affected. Let’s try another example, this time with your medical chart as you are about to undergo a medical procedure:

1. During the proceedings, your medical file is viewed by unauthorized personnel (confidentiality breach).
2. As the procedure is about to start, a glitch causes your medical file to be unavailable (availability breach).
3. Your medical file contains errors, leading to the wrong surgery being committed (integrity breach).

Again, we see the distinction in injury between the breaches. A last one example. You are in danger and call 911 to get emergency assistance:

1. People using police band scanner get details of the call (confidentiality breach).
2. There is no answer because the system is overwhelmed or broken down (availability breach).
3. The call goes through, but a mistake is made when identifying the location and emergency services are dispatched to the wrong address (integrity breach).

Common terminology

As we can see, there is a need to understand the information system and what it is used for to be able to define a level of injury for potential breach scenarios. We have seen the labels for confidentiality of both Protected and Classified information. What about integrity and availability?

There is no universal labelling system for integrity and availability. In the next section, we will look at some of the official sources for guidance and best practices and see how they label the information. A common approach is to define the injury as LOW, MEDIUM, or HIGH, or other labels with similar definitions.

Understand injury

By now, you have a better understanding of the notion of injury assessment, conducted through an injury test. You also saw examples of situations and scenarios in which we can perceive of a potential level of injury. We were able to observe that confidentiality, integrity, and availability are not always at the same level in a given information system and should therefore be assessed independently.

In the next section, we will look at specific approaches for labelling.

Official guidance

Federal governments handle large amounts of private information pertaining to their citizens. This can be statistical information, medical information, financial information, or any other type of information that has a level of sensitivity and privacy attached to it. Not all governments apply strict measures to adequately protect the privacy of this information, but Canada and its partners do. You will see some of these classification methods in this section.

Private organizations are not held to federal standards, but they are submitted to laws and regulations regarding privacy and must comply with security requirements when they collect and store private information, including regular security audits.

NIST guidance

The National Institute of Standards and Technology, NIST, provides guidance and recommendations to US federal organizations, and their advice and guidance is recognized and used by many other countries, including Canada.

NIST Special Publication 800-60 is a guide for mapping types of information and information systems to security categories.

The complete NIST SP 800-60 is available here:

NIST recognizes three levels of injury, which they call “Potential Impact”. The levels are Low, Moderate, and High. (Note that NIST uses the term moderate instead of Medium). The rating is meant to apply to the overall injury for loss of confidentiality, integrity, or availability. Here are the complete definitions:

- Low: The potential impact is low if—The loss of confidentiality, integrity, or availability could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals. A limited adverse effect means that, for example, the loss of confidentiality, integrity, or availability might: (i) cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced; (ii) result in minor damage to organizational assets; (iii) result in minor financial loss; or (iv) result in minor harm to individuals.
- The potential impact is moderate if—The loss of confidentiality, integrity, or availability could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals. A serious adverse effect means that, for example, the loss of confidentiality, integrity, or availability might: (i) cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced; (ii) result in significant damage to organizational assets; (iii) result in significant financial loss; or (iv) result

in significant harm to individuals that does not involve loss of life or serious life threatening injuries.

- The potential impact is high if—The loss of confidentiality, integrity, or availability could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals. A severe or catastrophic adverse effect means that, for example, the loss of confidentiality, integrity, or availability might: (i) cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions; (ii) result in major damage to organizational assets; (iii) result in major financial loss; or (iv) result in severe or catastrophic harm to individuals involving loss of life or serious life threatening injuries.

GC guidance

The Government of Canada used the NIST recommendations and created its own standard on security categorization. Appendix J of the Directive on Security Management details the security categories. The standard defines two different approaches. It is possible to provide a unique overall label for the security requirement that accounts for confidentiality, integrity, and availability of the information system. The label is then one of the following: Very High, High, Medium, or Low. If the approach is to provide a label for confidentiality, integrity, and availability separately, then the approach will be as we covered previously. The information will need to be attached to either national or non-national interests, and the confidentiality label will be applied accordingly. This means confidentiality is rated Protected A, B or C for non-national interests, and Confidential, Secret, or Top Secret for national interests. Integrity and availability are rated independently as well and receive a label of High, Medium, or Low.

Cloud guidance

This brings us to the notion of cloud services and their providers. The discussion moves from the injury assessment to the deployment infrastructure using the same terminology.

For example, if an information system is labelled Protected B, Medium integrity, Medium availability (PBMM), then we have at a glance the result of the injury test for all three main attributes of information security. This assessment is based on the nature of the information and what the system is being used for, as we saw with the examples. This labelling will guide the security effort and determine which security controls are adequate to protect from the injury. In other words, the organization needs an infrastructure that is suitable for a PBMM deployment. If the organization develops an on-premises solution to house the application, they will ensure that the security of the solution is on par with a PBMM requirement.

When organizations were confronted with the prospect of a cloud migration for their applications, the question that would routinely come up from security experts was: “Can the cloud service provider give us a deployment suitable for our security requirements?”

As you can see from the contents of this module, that question is difficult to answer. Different organizations have different terminology, and private organizations, such as cloud service providers, do not use the same classification labels as government organizations. There was a disconnect in the language that made security decisions very complex.

At that moment, government entities saw the need for a common language being used to define the security level of cloud offering to facilitate migration to cloud without creating security risks.

In the rest of this section, we will look at the US Government FedRAMP classification, and the Canadian Government equivalent.

FedRAMP classification

The Federal Risk and Authorization Management Program (FedRAMP) provides a standardized approach to security authorizations for Cloud Service Offerings.

The FedRAMP initiative is a process by which cloud offerings are assessed for security and can be pre-authorized for levels of security requirements. Find out more at their official website:

From the FedRAMP resource on baselines and impact levels: “With FedRAMP, cloud service offerings (CSOs) are categorized into one of three impact levels: Low, Moderate, and High. The are categorized across three security objectives: Confidentiality, Integrity, and Availability.”

This approach is in line with NIST guidance, where the assessment determines if a cloud service offering is suitable for information systems corresponding to a Low, Moderate, or High impact.

GC Security Control Profile for Cloud-based GC Services

When it comes to cloud deployments, the Government of Canada used its own approach, feeling that the FedRAMP classifications did not exactly align with their assessments. Their approach is similar to what FedRAMP does but takes into consideration specific

concerns of the Canadian context.

The Government of Canada chose to label cloud service offerings using a combination of three independent ratings for confidentiality, integrity, and availability. Find out more at the official reference guide:

However, the implementation of the guidance ended up being very similar to the FedRAMP classification. GC guidance recognizes two profiles for cloud deployments: Low and Medium. There are no cloud service offerings recognized by the Government of Canada as being suitable for High impact information systems.

Common language

Even though the industry is not using universal descriptors for security requirements and suitability, initiatives like FedRAMP serve to provide a communication baseline between customers and cloud service providers. Through that initiative, cloud services providers can create an offering and have it assessed and certified through a FedRAMP process. When an offering is certified to FedRAMP Medium impact, customers have a much better idea of what to expect from the start. Cloud services providers can use their FedRAMP certification to advertise their offerings.

Summary

Conclusion

In this module, we observed some of the implementations of security requirements and security categorizations. We use the injury test to analyze some scenarios and we were able to observe how the injury test leads to a sensitivity label which can then be used to define the suitability of a cloud offering to house an application. We talked about the FedRAMP initiative and how it helps to create a baseline for a common language to measure security ratings of cloud offerings.

In the next module, we will look at an important administrative security control: the acceptable use policy and general security policies.

References

The references listed here, coupled with the course developer's experience, have been used in the development of this module:

n.a. (2008). Guide for Mapping Types of Information and Information Systems to Security Categories. NIST. Retrieved from https://csrc.nist.gov/pubs/sp/800/60/v1/r1/final

n.a. (2016). Government of Canada Security Control Profile for Cloud-based GC Services. Government of Canada. Retrieved from https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/cloud-services/government-canada-security-control-profile-cloud-based-it-services.html

n.a. (2017). Understanding Baselines and Impact Levels in FedRAMP. FedRAMP. Retrieved from https://www.fedramp.gov/understanding-baselines-and-impact-levels/

n.a. (2020). Working With Sensitive Information. Government of Canada. Retrieved from https://www.canada.ca/en/department-national-defence/maple-leaf/defence/2020/12/working-with-sensitive-information.html

Bonderud, Douglas (2015). The Ashley Madison Security Breach: An Affair to Remember? Security Intelligence. Retrieved from https://securityintelligence.com/news/the-ashley-madison-security-breach-an-affair-to-remember/

Drea, Edward J. (2018). ULTRA. Encyclopedia.Com. Retrieved from https://www.encyclopedia.com/social-sciences-and-law/political-science-and-government/military-affairs-nonnaval/ultra

Module 8 | Security policies and acceptable use

A security policy records an organization's expectations and decisions so people can act consistently. This module explains the purpose, audience, scope, awareness, acceptable use, and practical creation of information security policies.

Introduction

Often seen as a "softer" security control, security policies nevertheless play a critical role to define, publish, inform, and enforce security requirements throughout an organization. This module will explain the use of internal policies for organizations, but also the constraints brought forward by applicable laws and regulations that organizations must comply with.

Learning Objectives

By the end of this module, you should be able to complete the following:

1. Recall the goals and objectives of a security policy.
2. Recall tips and approaches to make the security policy efficient and successful.

Information security policy

The notion that this module will focus on is how to develop and use efficient security policies that correspond to security concerns and implement adequate security controls and mitigations.

Quick Start

In the previous video, you got a general sense of what the task of writing a policy could look like. Of course, you can't become a policy analyst with five minutes of explanations, and neither will you be at the end of this module. The goal of this module is rather to understand the general approach that goes into crafting a policy that encapsulates the rules of the organization as they apply to a specific target audience.

Using policies

Policies are used in a similar fashion as laws and regulations within an organization. As with laws and regulations, policies will require many attributes to make them useful and applicable in the organization.

Have a look at some of those attributes in the sections below:

Awareness of policies

Do you know the criminal code? Are you aware of all the laws that apply to your behaviour? Probably not, and that is normal. The same applies in organizations, where very few people are aware of all the policies, regulations, directives, and standards that apply.

So how is an organization supposed to react to this? There needs to be prioritization of the awareness to certain policies. For instance, a popular policy in many organizations is called "Acceptable Use Policy" or AUP. It details what is acceptable to do or not on the corporate network. Can I check my Instagram? Can I check my personal emails? Can I Zoom call my mom? Can I play Spotify over the network? To answer these questions, the organization can create and maintain an AUP and provide the document to the employees as they are granted credentials and network access. Some organizations convert the AUP into a contract, where the employee must sign that they have read the document and will abide by the rules. If the organization is noticing that employees are not complying with the AUP, they can then send a general reminder to the employees. If a specific subset of employees is the problem, they can be targeted for specific training and awareness. If the bad behaviour persists, then what? That is something that the policy should define: consequences of non-compliance. In some cases, it can lead to termination of employment.

The attribute here is the publicizing of the policy to the target audience: they need to be made aware of the existence of the policy and be reminded of the rules in it as required. For instance, we are reminded about some laws regularly, such as against impaired driving. You don't need to wonder if it's illegal or not, the message gets through loud and clear. With organizational policies, the same approach will be used. Awareness and training will be used to promote the higher-priority policies.

Applicability

Although it may surprise you, the biggest obstacle to implementing a policy is whether or not the target audience will abide by it or not. When policies and regulations do not make sense to the people that it applies to, they will choose to ignore it or circumvent it somehow. Unless the people targeted by the policy understand the importance of the rules and accept to comply with it, the policy will fail. There are plenty of examples of such behaviour, and all you need to do is look around. When a small number of people disobey the policy, there can be actions and consequences applied and the behaviour can be corrected. When the disobedience is widespread and consistent, the rule-makers will not be able to enforce the rules without causing chaos and disruption in the workplace.

Therefore, policies must be carefully constructed so that they are applicable in a way that makes sense for everybody. There is a psychological principle called “peer consensus and social proof” that states that people will validate their behaviour based on what other people around them do. Think about it: imagine that you start a new job, and you get provided with rules to follow. But then, if your coworkers tell you that they don’t follow those rules you probably won’t either, especially if you would be the only one to do it.

Now, consider the following example. An organization sets out a new sick day policy saying that they simply won’t accept them anymore. The previous rule was that a doctor’s note was required, but now the company says: “if you are well enough to go see a doctor, you’re good to come to work”. This policy would not go down well of course, and employees would protest and leave the workplace if no changes are brought.

Relevance

Policies are created and implemented to address a problem or a concern, maybe to fix a situation or to prevent it from occurring. There will always be an issue that a policy is trying to tackle, otherwise the policy is not needed at all. In the same sense as applicability, the policy must be relevant to the problem that it tries to address. For example, if the company is noticing that many people are getting in late to work, they might wish to address the situation with a policy. If the policy implements a rule that shortens the lunch break by 15 minutes, employees would be justified in wondering, “how does that help?”. The rule would punish people that come in to work on time, justifying them into getting in late to compensate for the shorter lunch break. In short, the rule might be counterproductive to the situation.

And of course, situations evolve and the context from several years ago when the rule was implemented may not apply at all anymore today. Rules that have lost their relevance should be rescinded to preserve the relevance of active rules as a whole.

Principles of a policy

As you can see, there are basic principles to consider when crafting, distributing, and enforcing a policy to an organization. In the next section, we will explore how this can apply for information security policies.

Security policies

In this section, we will start by discussing the importance of security policies, then we will look at the different types of security policies, and finally we will look at the elements of an effective security policy.

The content of the section is largely based on the following article:

Importance of security policies

Organizations can underestimate the vital importance of security policies. Experienced and well-established organizations understand just how critical establishing well-crafted policies can be to the overall functioning of the organization.

As stated in the article that you have just read, here are some of the benefits that clear policies can provide to an organization:

1. Guides the implementation of technical controls.

To be clear, the policy does not concern itself with the details of the technical implementation of security controls. However, it can provide guidance to how the process should be accomplished: who performs the risk assessment, who is in charge of authorizing the deployment, who can perform the actual task, who will verify that the security control performs as intended, etc. In fact, a type of policy called “Roles and responsibilities” is an extremely useful document for just about any organization. It states who is in charge of which activity, and just as importantly who does not have the authority to act in those situations.

2. Sets clear expectations.

Policies can be a very effective communication tool. A great contribution that policies can bring to the organization is to remove uncertainty and doubt about what is expected from employees. This can include policies like the Acceptable Use Policy that we discussed before.

3. Helps meet regulatory and compliance requirements.

As we've discussed in previous modules, organizations can be subjected to very specific laws and regulations. By law, when an organization collects private information about their customers, they must adequately protect that information. By enabling internal policies that align with legal and regulatory requirements, the organization can demonstrate their efforts towards compliance.

4. Improves organizational efficiency and helps meet business objectives.

It would be a mistake to see policies simply as a way to compel a certain behaviour from employees. In fact, policies can greatly help to increase the operational efficiency of the organization. When policies are well-defined and are used to create and enforce operational procedures, they can help employees to accomplish their tasks in a clear and repeatable fashion.

Types of security policies

Security is a broad subject and requires many different tools to enact across an organization. Security policies are one such tool, and often a starting point to enable other aspects of security, some more tangible than others.

Once again in this course, we use advice and guidance from the National Institute of Standards and Technology (NIST). According to NIST, there are three distinct types of security policies.

The three types of policies are defined in the NIST Special Publication 800-12, an excellent introductory document to establish information security at the organizational level:

1. Program policy.

These policies can be described as a "top-down" approach, since the goal is strategic and determined at higher executive levels to be passed down at the operational level for implementation. They can be intentionally vague, so as to give room for the operational workforce to interpret. For example, the program policy might require that all applications are evaluated according to an organization-approved threat model. Which threat model to use, and how the procedure will unfold is not specified in the policy. The actual procedure might evolve and be refined over the years without requiring the policy to be updated at all.

2. Issue-specific policy

This type of policy is the opposite, more of a "bottom-up" approach. When the operational teams notice a specific type of issue, they can raise the problem and even offer potential solutions to the problem. If the executives approve of the path forward, they can enact a new policy that will target that specific issue. As an example, imagine that a software development team is starting to rely on AI tools to help them write code. The behaviour exposes the organization's intellectual property to an outside third party, i.e., the AI software, and the operational staff sees this as a security issue. The policy can be enacted to provide direction and rules to the use of AI for operational needs.

3. System-specific policy

Some policies have a very, very limited scope. They can apply to a specific device, such as a computer or a printer, and that device can be used by a limited number of people. The policy might state some specific rules regarding that system or device for the people that will use it. For instance, if the company purchases a costly plot printer, there might be a policy towards the use of the device: training required, acceptable use, etc.

Elements of an effective security policy

As you quickly saw in the introductory video, a policy will have typical components, and does not need to be a complex document. Actually, it can greatly benefit from simplicity and clarity. Therefore, it is best to use specific language and terminology, including a glossary to remove ambiguity.

Here are the seven elements of an effective security policy:

1. Clear purpose and objectives

The policy should start by defining its purposes, objectives, and expected results. If this is not easy to define, it can be an indication that the policy makers do not quite grasp what problematic the policy is trying to address. If the policy is trying to tackle too many things at once, it indicates that there is a need to break down the policy into different documents that are more precise and concise. Namely, if the policy does not neatly fit into one of the three types of security policies that were defined previously, that is not a good sign.

2. Scope and applicability

The policy makers should be able to clearly state to whom the policy applies and in which context. This can be defined from many factors, and the more precise the better. For example, a travel policy can be defined that applies to all employees that travel for business purposes within Canada and the US.

3. Commitment from senior management

Regardless of whether the effort was a top-down or bottom-up approach, policies will end up being created, promoted, and enforced from the top. It is imperative that senior management recognizes the legitimacy of the policy and that they abide by it as well according to the scope and applicability of the policy. Policies typically state under which authority they have been issued.

4. Realistic and enforceable policies

As already discussed, unrealistic policies will be circumvented and ignored by the target audience. The policy must reflect the operational realities of the people that will have to implement it. For example, an email policy that states that each email received must be validated by phone or some other way before they can be actioned would be unrealistic for someone working in Finance or another position where emails pour in all day long. If the application of the policy increases the amount of work unrealistically, employees will not comply with it.

5. Clear definitions of important terms

The level of specificity of a policy can be an elusive target. The policy must have some wiggle room to allow for versatility and adaptability, but when the policy is so vague as to allow various interpretations, the meaning might be lost, and the goals will not be achieved. The policy must be clear in what is to be achieved, rather than how to achieve it. Any ambiguity as to the meaning of words used in the policy, especially technical terms, should be addressed by inserting clear definitions of these words according to their use in the policy. Annexing a glossary to the document is a typical way forward.

6. Tailored to the organization’s risk appetite

As we discussed in previous modules, security can be defined as the conceptual opposite of risk. When organizations enact security policies, it is to target and mitigate a perceived risk. This should be clear from the goals of the policy. Security will not be absolute of course, and the policy should reflect the organization’s level of comfort with the residual risk.

7. Up-to-date information

In the world of security, things can change very quickly. Policies are often seen as playing “catch up” to security situations, meaning that by the time the policy is drafted, approved, and implemented, the situation that it attempts to address has evolved to something else. It is important to see policies as documents that require upkeep in order to stay relevant in the ever-changing world of security.

Creating policies

As you can see, creating a policy is no simple task. It requires a deep understanding of the context in which the policy will be used, its potential operational impact, and the implications for work procedures and established standards. By using the guidance in this document, you will be better equipped to draft basic policies that define objectives and clear approaches to meeting those goals. In most cases, policies will require an adaptation period after which they can be revised and fine-tuned to better meet the realities of the organizational context.

Summary

Conclusion

In this module, we discussed the notions of a security policy. In a cloud environment, these policies are crucial to translate the security requirements of the organizations into the applications deployed to the cloud. The policy can target the development pipeline, remote connection, strategical oversight, laws and regulations, and much more.

In the next module, we will start a three-part discussion on the hands-on implementation of time-tested security principles.

References

The references listed here, coupled with the course developer’s experience, have been used in the development of this module:

n.a. (n.d.) Information Security Policy: Examples and 11 Elements of a Successful Policy. HackerOne. Retrieved from https://www.hackerone.com/knowledge-center/information-security-policy

Buckbee, Michael (2023). How to Create a Good Security Policy. Varonis. Retrieved from https://www.varonis.com/blog/how-to-create-a-good-security-policy

Casey, Kevin (2021). How to create an effective security policy: 6 tips. The Enterprisers Project. Retrieved from https://enterprisersproject.com/article/2021/10/security-policy-how-to-create

Grimmick, Robert (2023). What is a Security Policy? Definition, Elements, and Examples. Varonis. Retrieved from https://www.varonis.com/blog/what-is-a-security-policy

Laird, Jennifer (2022). Creating an IT Security Policy. Privacy Policies. Retrieved from https://www.privacypolicies.com/blog/it-security-policy/

Nieles, Michael, Dempsey, Kelley and Pillitteri, Victoria (2017). An Introduction to Information Security. NIST. Retrieved from https://csrc.nist.gov/pubs/sp/800/12/r1/final

Module 9 | Security principles

Security principles help turn broad goals into repeatable decisions. The module covers principles for aligning security with an organization's mission and costs, and implementation principles such as least privilege, separation of duties, and two-person integrity.

Introduction

In this module, you will start a discussion on the hands-on implementation of information security. To get started, you will go over time-tested and recognized security principles. These principles guide the implementation of security decisions, such as the attribution of roles and privileges, and how certain operations should be conducted in compliance with the organization's established security rules.

Learning Objectives

By the end of this module, you should be able to complete the following:

1. Recall commonly recognized security principles.
2. Recall information security principles that guides the definition and implementation of organizational security controls.

Key Terms and Concepts

Principle of least privilege — In information security, computer science, and other fields, the principle of least privilege, also known as the principle of minimal privilege or the principle of least authority, requires that in a particular abstraction layer of a computing environment, every module must be able to access only the information and resources that are necessary for its legitimate purpose.

Risk appetite — Risk appetite is the level of risk that an organization is prepared to accept in pursuit of its objectives, before action is deemed necessary to reduce the risk. It represents a balance between the potential benefits of innovation and the threats that change inevitably brings.

Separation of duties — Separation of duties, also known as segregation of duties is the concept of having more than one person required to complete a task. It is an administrative control used by organisations to prevent fraud, sabotage, theft, misuse of information, and other security compromises.

Two-person integrity — The two-person rule is a control mechanism designed to achieve a high level of security for especially critical material or operations. Under this rule, access and actions require the presence of two or more authorized people at all times.

Conceptual Security principles

In this section, you will go over a list of globally recognized and accepted security principles. As the name implies, a principle is conceptual and guides the implementation of a security control rather than define it. It helps administrators to understand how to best apply their rules and regulations, namely when defining security policies, as you studied in the previous module.

Security principles have a longer lifespan that security rules and technical controls. This is because the technology evolves very quickly, but the underlying security principles that we use today in information security have been around for a very long time. Some of them date back thousands of years ago.

Even though it was written in the 5th century BC, the Art of War by Sun Tzu is still today considered a definitive work on military strategy and tactics. In cyber, which is now considered the fifth domain of warfare along with land, sea, air, and space, the rules of

Sun Tzu are used to inform security strategies. The following articles use the principles of Sun Tzu in a cyber security context:

The main document that will drive this module is a NIST publication called: Generally Accepted Principles and Practices for Securing Information Technology Systems.

The NIST document, published in 1996, provides useful information for information system security, including recognized and applicable security principles.

Security supports the mission

Security should never be applied just for the sake of applying security. However, that scenario might happen more often than we think. Security becomes a “check box” activity, where an assessor or auditor checks the implementation of security controls without regard to the overall contribution to the mission, or the effectiveness of the security controls.

This checklist approach violates this first security principle in different ways. First off, security is not an end in itself, but a mechanism to serve the overall organizational mission. Checklist approaches become popular when organizations want to tout their security practices, or when providers want to market their services to customers and boast of security controls that protect their infrastructure. It is also an unfortunate result of external constraints being applied to organizations, such as auditing requirements, or compliance with laws and regulations.

For example, consider that a third-party auditor comes to an organization to “check” the security. It could be from an insurance company, a government audit, or some other external pressure being applied to the organization. The organization will almost see the auditor as a threat. If the audit is not successful, the organization might be required to spend a lot of time and money to increase their security to meet the requirements. Therefore, the goal of the organization is to “pass” the audit. If issues are found, they will look for the quickest, easiest, and cheapest way to make them go away. This is a very different perspective than using the exercise to uncover flaws and vulnerabilities and be able to address them. The audit, even though well-intentioned and necessary, can be an exercise in futility.

Security should not be an obstacle to operations, but rather a way to support them. The organization has a mission and objectives, and they want to meet these goals without being exposed to security threat. This is how security should be viewed: providing protection to assets and operations. The paradigm of DevSecOps is intended to function exactly like that: where security is combined to development and operations, and they all work towards the same goal.

Security is an integral element of sound management

Security, as you know, will not be an all or nothing proposition. It’s not as if an asset is unsecured, and now it is because we added a security control. There are levels of protection, and some offer better security than others.

For example, an account can be protected using a password, and that offers a level of protection. Then, you can increase the level of protection by apply a password policy: how passwords must be created (size, complexity, rotation, etc.) You can argue that the level of security would be increased by this. Then, you can add additional security controls, for example to protect passwords at rest on the server-side. This provides another security increase. If detection mechanisms are added that can spot anomalous use of accounts, warnings to administrators, and so forth, the security goes up even higher. You can also consider adding two-factor authentication to the accounts.

In short, there are multiple security controls that could be added, and we could expect that they will increase the level of security. So, the question becomes, how much is enough? To answer the question, you must consider the cost of the additional security controls, and the sensitivity of the assets that they protect. The organization must understand their “risk appetite” and deploy security controls in accordance with this.

Security should be cost effective

This principle aligns with the previous one, in the sense that risk appetite will be correlated to the cost of security controls. If cost, meaning financial cost, time, expertise, and all the rest, was reduced to zero, you could expect companies to raise the level of security to their operations dramatically. Even though the cost has been going down for many years, it is still expensive to deploy security. The cost effectiveness of the security controls will be calculated by how much money they can save the company. In any case, this is a difficult assumption to make. Organizations can take into consideration the average cost of a security breach, and the likelihood that the security controls would prevent it to determine if they are cost-effective of not.

Security extends outside the organization

This principle has been discussed in previous modules, and in a cloud context, it is easy to understand. Cloud providers must consider their own security needs for their internal operations, but a lot of their considerations will go towards the level of security that their clients need to protect their own operations. These clients might themselves have databanks of private information that must be adequately protected.

For example, consider Netflix. If you are a client of Netflix, they have on file some of your private information, including credit card data. If they use a cloud service provider to host this information, they remain responsible for that data's security, and must ensure that the provider is securing the data adequately.

Responsibilities and accountability should be explicit

This security principle from NIST relates directly to our previous module on security policies. As we discussed then, a key component of a security policy is the scope and applicability, i.e., to whom the policy applies and in which context. Another key element would be the definitions of roles and responsibilities in the application of the rules defined in the policy. And finally, what can happen if the rules are not followed, an item often stated as "consequences of non-compliance". Here, NIST reinforces the notion that responsibilities and accountabilities should be clearly defined and communicated to concerned parties.

A very useful tool for this principle is the creation of a RACI matrix, a common component of policies and procedure. The acronym stand for:

- Responsible
- Accountable
- Consulted
- Informed

For a given procedure, stakeholders will fall in one of those four categories. The information can be made concise yet explicit with a RACI matrix. For more information, consult the following resource:

Security requires a comprehensive and integrated approach

Further argumentation against the "check list" approach is this NIST security principle. To be effective, information security requires a comprehensive approach that takes into consideration all the operations that can have an impact on security.

For example, a checklist security item could state: "antivirus software is installed on the user's computer". Many other considerations are not present, such as:

- How is the virus database refreshed?
- Can the user deactivate the software?
- If the software breaks down, will an alert be sent?
- If the software is not operational, can the system still be used?

Another similar example could be the use of a VPN for users to connect back to the organizational network.

Security should be periodically reassessed

Even though the security principles can themselves have a long lifespan, the security controls that they spawn probably won't be. This is especially true in cyber security, where the rate of change is drastic. What could have been adequate security for an information system only 10 years ago would be greatly lacking in today's environment. Threat actors, adversarial tactics, and available attack tools keep evolving and system defenders keep trying to catch up to the current level of threat.

Security is not a product, but a process that must evolve with both the organizational environment and the threat context. Therefore, it requires constant monitoring, reassessment, and adjustment to remain relevant and sufficient.

Security is constrained by societal factors

It might be counter-intuitive, but there is often a trade-off that occurs between security and privacy. For example, if a provider requires that authentication includes a fingerprint or facial scan, that information must be collected by the provider and would be seen by many as an invasion of privacy. The same concept applies when a provider uses the customer's phone number for authentication or other uses.

During the pandemic, many employees converted to a “working from home” mode, and after restrictions were lifted, many have kept on partially or completely working remotely. Many employers were reluctant to adopt this way of working, assuming that remote workers would not be as diligent in their duties without the constant supervision that working in an office provides. Some of them implemented electronic monitoring tools in employees’ computers to flag unproductive employees. The situation became alarming to a point where legislation was introduced in Ontario to force employers to disclose the information to workers about whether they are being electronically monitored.

The following article describes the issue of transparency when it comes to monitoring, or “spying” on workers by the employees:

Although it might feel like remote monitoring is a very special case of security vs privacy, the same type of dilemma frequently occurs. Matters of logging, monitoring, and auditing will happen without necessitating additional software on the computer. The often-used statement of “it’s for security purposes” will be used by providers to justify privacy intrusions. Pushing back on privacy infringement is necessary, but it also means that it will make some security measures fall out of reach of the providers.

Implementation-level security principles

Now that you have looked at the conceptual security principles, as defined by NIST, you will now look at more straight-forward security principles that can guide the hands-on implementation of security rules.

In this section, you will analyze the principle of least privilege, separation of duties, and two-person integrity.

The principle of least privilege

The principle of least privilege might be the most important security principle for information systems. You have extensively covered the notions that go into defining levels of sensitivity for information, such as Protected of Classified data, and the requirements to access such information. This principle aligns with such considerations by asking:

“What is the minimal allowance of privileges that I can grant this user, device, or process that will allow operations to continue?”

The question is an interesting one and can be viewed in many ways. Let’s look at some examples.

- Use unprivileged accounts

In Windows 10, user account types can be “Regular” or “Administrator”. Administrator accounts can modify settings, add applications, and generally manage the system. It is recommended that users only use regular accounts until additional privileges are required. Basically, they should invoke administrator privileges when there is a need to perform administrative tasks. The reason for this, is that if a malicious process invades the computer, it will be limited by the privileges of the current user, and the damage might be reduced. Another reason relates to user error, where the amount of damage caused from an accidental operation is limited.

- Run services with dedicated accounts

Early iterations of Linux servers would start services at boot time using the administrator account, i.e., the root account. The processes then would run in the background with a high level of privilege. If a hacker managed to hijack the process, they would then have an administrative access to the device and be able to do anything. Today, the approach is to provide dedicated accounts for these services, and to run them at the lowest level of privileges required.

- Provisioning user accounts

This should be a common application of the principle. When users receive an account, it is to accomplish tasks related to their duties. Which privileges should the account be granted? Well, the organization might want the user to be unimpeded in their tasks and might actually advocate for a higher level of privileges that is absolutely required. The user might have the same perspective, wishing for a higher level of control that required. For example, a developer might argue that installing software and utilities on their development computer is a requirement for their tasks. The organization might be inclined to agree. But from a security perspective, the process would be seen as more secure if such privileges are not granted, and the developer must create a request to have the software installed instead. This provides better monitoring of installed software and can limit the likelihood of malware being installed on the device.

The principle of least privilege can be applied in various situations to great effect. Read the following article for more details on the benefits of using this principle in security-related decisions:

Separation of duties

In many ways, the security principle of separation of duties is a specification of the principle of least privileges. However, the implementation of this principle can involve other considerations that simply granting privileges.

The basic principle of separation of duties requires that no individual person shall be able to execute all parts of a transaction of process. This is a control principle that aims to avoid having users assume the control of an entire operation. For example, if a user is able to make a request for computer equipment, approve that request, and then action that request, there is a lack of control and overview in the process. Obviously, the request should be justified by the requester, validated by another entity, and then actioned by yet another. It reduces the risk of conflict of interest, errors, fraud, abuse, or theft.

To apply this process towards information systems, organizations must consider processes and define a sequence of implementation that is adequate to protect the integrity and security of the process. For example, a user should not be able to grant privileges to themselves.

For more details on the notion of separation of duties, consult the following article:

Two-person integrity

The security control of two-person integrity is another way to reduce the risk to certain operations. Some processes cannot be broken down into different parts that allow for the implementation of a review and approval process, and instead require swift and immediate application. In those situations, to avoid having the process rely on one individual, the two-person integrity rule can be put in place. This will require that two individuals agree to simultaneously engage into the action. This can be seen in military situations, such as launching a tactical strike, or in financial situations like opening a bank vault. The concept is also used in cryptography, where an encryption key is broken into several parts and decryption requires all participants to engage and provide their part of the key.

For the control to be effective, both individuals involved must be able to recognize if the process should legitimately occur or not, otherwise the additional person does not grant higher security.

Security principles overview

This section has allowed us to discuss certain security principles that can help defining security controls in a more efficient way. The checklist approach will not consider the overall establishment of security controls and can miss security holes. The same holes will be discovered by a dedicated and persistent adversary. Applying time-tested and proven security controls using an overall strategy to secure information systems will provide better results.

Summary

Conclusion

In this module, you covered security principles going from overarching conceptual principles to more hands-on specific principles in the establishment of privileges and access controls.

In the next module, continue this exploration by analyzing the implementation of strategies for roles and responsibilities that reflect the organizational structure.

References

The references listed here, coupled with the course developer’s experience, have been used in the development of this module:

n.a. (n.d.) Separation of Duties. Imperva. Retrieved from https://www.imperva.com/learn/data-security/separation-of-duties/

Madsen, Tom (2017). Sun Tzu's 'The Art of War' for Cybersecurity. Infosecurity Magazine. Retrieved from https://infosecurity-magazine.com/opinions/sun-tzus-art-of-war-cybersecurity/

Maloney, Andrew (2021). How to apply Sun Tzu’s ‘The Art of War’ to cybersecurity. Security Magazine. Retrieved from https://www.securitymagazine.com/articles/96072-how-to-apply-sun-tzus-the-art-of-war-to-cybersecurity

Patel, Nisha (2022). Is your boss tracking you while you work? Some Canadians are about to find out. CBC News. Retrieved from https://www.cbc.ca/news/business/canadians-workers-employers-tracking-1.6612228

Rivera, Maricel (2022). The RACI Matrix Explained. The Ascent. Retrieved from https://www.fool.com/the-ascent/small-business/project-management/articles/raci-matrix/

Swanson, Marianne M. and Guttman, Barbara (1996). Generally Accepted Principles and Practices for Securing Information Technology Systems. NIST. Retrieved from https://www.nist.gov/publications/generally-accepted-principles-and-practices-securing-information-technology-systems

Vaideeswaran, Narendran (2023). What is The Principle of Least Privilege (POLP)? CrowdStrike. Retrieved from https://www.crowdstrike.com/cybersecurity-101/principle-of-least-privilege-polp/

Module 10 | Access controls

Access controls determine which subjects can perform which actions on which resources. This module examines discretionary, attribute-based, mandatory, and role-based approaches, as well as management, operational, and technical controls.

Introduction

In this module, we continue our discussion about hands-on security implementation with the notion of access controls. You will learn about some of the considerations that organizations use to grant or deny access to resources and assets. This can be used in your career when you may be required to set up and maintain access controls.

Learning Objectives

By the end of this module, you should be able to complete the following:

1. Recall the use of access controls.
2. Recall the categories of access controls.
3. Define the types of implementations for access controls.

Key Terms and Concepts

Object — In computer security, the object is what can be granted access to or not. For example, files, folders, devices, and applications are objects.

Principal — A principal in computer security is an entity that can be authenticated by a computer system or network. It is referred to as a security principal in Java and Microsoft literature.

Subject — In computer security, a subject is an entity that can interact with objects. For example, users, roles, processes, connection requests are subjects.

Access controls

Access controls are very likely to be the most critical aspect of an organization. After all, access controls are the tools that grant access to authorized people to certain resources and assets and deny anybody else. If access controls fail, then legitimate users may be denied from accomplishing their duties, or malicious individuals may target the organization’s assets for their own advantage. Controlling the access is fundamental and key to a well-functioning organization.

Controlling the behaviour

When we think of access controls, a common approach is to think about controlling the behaviour of individuals. However, it is also important to note that this control extends to processes and devices, which are used by people to accomplish actions. In a cloud setting, access is typically remote, so the control is applied to virtual instances and is less physical than for traditional implementations.

Access controls rely on authentication and authorization mechanisms. In order to grant or deny access, the level of confidence towards the identity of the entity needs to be adequate. Individuals and processes are commonly referred to as “subjects”, and the resources and assets that they wish to have access to are referred to as “objects”

Failing access controls

Access controls must be efficient. This is obvious, but it is not rare that access controls fail spectacularly to accomplish their task.

The Open Web Application Security Project, known as OWASP, maintains a list of the most common vulnerabilities in web applications. This is the OWASP Top Ten project, and in the last revision done in 2021, they rated “Broken Access Control” as the most common security vulnerability. Their research indicated that a whopping 94% of applications tested indicated that 94% of

applications were tested for some form of broken access control.

OWASP provides worldwide-recognized advice and guidance on application security. Their Top 10 project rates Broken Access Control as the main security vulnerability in online application today.

This goes to show that access controls can be a challenge to implement correctly. We've discussed several security challenges in the course so far, including applying minimal privileges, properly separating duties, and requiring two-person integrity. Many things can go wrong in the implementation of access controls with the results ending up far from the desired outcome. As we discussed previously, a "check mark" approach to the existence of security controls does not automatically lead to a proper implementation of access controls.

Using access controls

We understand that an access control is meant to allow or deny a certain behaviour to an individual, process, or device. This is very vague and requires more details for an implementation strategy. Let's start by looking at the strategies for access control implementation in the next section.

Strategies for access controls

When discussing the implementation of strategies to define the access controls, there are four types of strategies commonly used. In this section, we will analyze each type: discretionary, attribute-based, mandatory, and role-based.

Discretionary access controls

Discretionary access controls, or DAC, are the simplest and most straight-forward access control there is. Privileges are granted to the entity directly, for example:

- Allowing a certain user is to read a file.
- Allowing a process is allowed to send content to the printer.
- Denying a network connection to an endpoint.

DAC is used to implement a clear decision from the organization's point of view. It applies the control directly. In accordance with the minimal privilege principle, security experts recommend that no privileges be granted by default, so that unless a privilege is explicitly granted to the principal, it is denied.

DAC can be difficult to maintain and apply because it requires a lot of work. For example, if a user request access to a resource, what rules should apply to determine if the privilege should be granted? DAC is a basic approach for privileges, but it does not scale well when managing a large group of principals and assets. The following document from IBM provides a formal definition of a discretionary access control:

Attribute-based access controls

Attribute-based access controls, or ABAC, uses characteristics of assets and principals to help determine how to grant or deny access. Using attributes can give a bit more flexibility to the use of access controls. When establishing rules to grant or deny access, attributes of the transaction can be used to make the decision. For example:

- During business hours, the main door is unlocked. After hours, only security and emergency personnel are allowed.
- A file repository can be accessed from any computer in the corporate network. External access is denied.
- Employees can access the Intranet from the corporate network. Contractors cannot access it, even from the corporate network.
- Employees assigned to a specific project can access the project's resource folder.

In each example, we use attributes of the resource and/or principal to determine if the interaction is allowed to happen or not. This is a more versatile approach and helps with a global implementation of access controls by streamlining the decision process. However, it lacks certain specifications for more complex and nuanced situations.

The following article defines what is an attribute-based access control, also known as a policy-based access control:

Mandatory access controls

Mandatory access controls, or MAC, seek to address the notion of security clearance in the realm of access controls. As you will recall from a previous module, certain assets are defined to a level of sensibility, like Protected B or Top Secret, and require that a principal accessing the resource possesses the corresponding security clearance to access it. MAC will supersede DAC and ABAC

in the sense that, even when DAC and ABAC rules would grant access, it will still be denied access if the security clearance is not provided to the principal.

This approach will be necessary in organizations that deal with sensitive information, as we discussed in a previous module. Most organizations do not have MAC rules in place. It is more commonly seen in government and military settings.

Mandatory access controls are not as common as other approaches, but are an important strategy for organizations dealing with sensitive objects. More details on the strategy can be found here:

Role-based access controls (RBAC)

A very useful method of defining privileges is to use the role-based access controls, or RBAC. In this approach, we combine DAC and ABAC by using the role of the subject to determine whether access should be granted or denied.

RBAC has gained in popularity by providing a versatile and convivial strategy for privileges and as such, it is now commonly implemented in many organizations. RBAC blends well with the organization hierarchy. The way that RBAC works, is that instead of applying DAC to the subject, it is applied to the conceptual role that the subject embodies. This means that subjects do not receive privileges but are instead assigned roles. The roles receive privileges. For example, consider an organization and one of its employees named Carl. Carl just started working at the company and is assigned the role of a finance officer. When Carl logs in, that role is attached to his identity. Carl can access the Finance application because his role allows it. When Carl attempts to access the intranet, he is allowed because he is also in the role of “Employee” and that provides certain privileges. When Carl tries to access the HR application, he is denied because that access is restricted to roles in HR. If Carl is transferred from Finance to HR, the roles will be modified. Carl will still be an employee and the privileges attached to that will stay, and Carl will also get the privileges that come with a role in HR. The privileges granted to those roles do not change: only the assignment of Carl to those roles will need to be modified. If Carl leaves the company, the roles will be removed, and he will no longer be able to access objects.

As you can see, the use of RBAC is easier to manage and understand. It is intuitive and justifiable. For example, if a subject requests access to an object, instead of spending time determining if the request should be granted and for whatever reasons, the decision is based on the roles of the subject. If the roles do not grant access, then it either needs to be revised if it’s incorrect or the decision stays

The following resource clearly explains how a role-based access control can be defined at the organizational level:

Applying a structure of access controls

Defining access to roles can be a difficult task, but since the roles will typically be more stable than individuals, it can be a good investment over time. It also helps to avoid a situation known as “scope creep”. Scope creep occurs when an individual has been with an organization for a long time and has occupied different roles during that time. When a new assignment occurs, the individual requests access and the request is granted to satisfy the new responsibilities. However, when the assignment is completed, the privileges are rarely revoked. Subjects enjoy the additional privileges and are unlikely to ask for them to be taken away. Over time, the number of privileges increases, leading to scope creep.

Role-based access controls are recognized today as an efficient strategy to apply privileges through roles. It allows subjects to use different roles in different situations and makes privileges attribution a more granular process rather than an “all-or-nothing” proposition. For example, a network administrator can log onto the system as IT practitioner or administrator depending on the task at hand. The privileges used will be different. It is the same subject, but a different role that will be used.

In the next section, we will look at the access controls themselves and how they are defined.

Classes of access controls

In the previous section, we discussed the strategies for the implementation of security controls. This is towards the decision: do we grant the subject access to the object? The decision is obviously a great part of the process, but how do we enforce the decision? This will of course be just as critical. We will see three broad classes of access controls and how they are applied in an organizational context.

Management access controls

The first class that we discuss represents management access controls. This is how the organization will determine who makes the decisions and what consideration go into the process. This class is often seen as the strategical application of security controls.

Management access controls will be used to define roles and responsibilities. When we discussed RBAC, we defined the strategy as applying privileges based on the subject's role. Management access controls will include this definition and attribution of roles to subjects. It includes the organizational chart where relationships between roles are defined: i.e., a reporting and supervision structure.

Another big part of the management access controls includes the security policies and directives that were discussed in a previous module. These documents are defined at the organizational level and have a scope of application, also using a role-based approach. The policies reflect organizational concerns, such as risk that the organization wishes to avoid.

Operational access controls

The class of operational access controls flows from the policies and directives that have been defined. This class includes the day-to-day application of security rules. It is often referred to as the tactical application of security controls.

Common controls seen in this class include training and awareness, physical security such as cameras and locked doors, and the background check performed on individuals prior to granting access to the organization's resources and assets. This class is also the one that deals with monitoring and incident response. All these controls required that a strategical implementation be implemented first in order to guide the tactical application.

Technical access controls

The third class of security controls can be seen as the glue that ties everything together. It is the use of technology to enforce the behaviour of the subjects. Here, we will see controls such as identification and authentication of subjects, cryptographic security for files and communication, and every other tangible use of a security control to enforce an access policy.

Monitoring and supervision

As you can see, the implementation of a security strategy through access controls can be a difficult proposition. Many implementers are driven to the technical application first, but defining a clear and flexible strategy will often prove to be much more beneficial in the long term.

Module 11 | Identification and authentication

Identification names an entity; authentication evaluates its identity claim. The module distinguishes identities, roles, and privileges, compares authentication factors and confidence levels, and surveys local, centralized, single sign-on, and cloud identity platforms.

Introduction

In the third and final part of the discussion on the hands-on implementation of security controls, we come to the discussion surrounding the critical aspect of adequately identifying subjects that interact with the organization's resources. Without reliable authentication, no security strategy can be successful.

Learning Objectives

By the end of this module, you should be able to complete the following:

1. Recall the concepts surrounding identification and authentication.
2. Recall the authentication factors.
3. Recall the supplemental factors for authentication.

Identification and authentication

In this module, we will do a detailed analysis of the notions of identification and authentication. Authentication measures are part of the access controls, but they are also more than that. They are the basic premise through which roles can be applied, privileges can be granted, actions can be monitored, and restrictions can be enforced. Without adequate authentication, no security control policy or strategy can be successful.

That last statement brings forth several questions: what constitutes "adequate" confidence in the authentication process? How is an authentication process defined? We will explore these questions in this module.

Digital identities

As humans, we think of ourselves as tangible, definable individuals. We interact with each other in that assumption, and we "recognize" each other with high levels of certainty. That's why we pick up the right kids at school and greet our coworkers by the right name. Sure, we make mistakes from time to time but for the most part this works well.

Computers, however, are not able to recognize people in the way that we do. It is true that some information systems are getting better and better at this passive identification, but the typical system out there is not yet well equipped to recognize individuals. Furthermore, as soon as we add a notion of remote access, even humans need a mechanism to identify who we are interacting with. In that sense, we resort to what we call "digital identities".

A digital identity uses virtual markers to identify someone or something. For example, if you receive a text message from a friend, how will you know who it's from? Are you going to analyze the content of the communication for clues? No, you will know who it is because your phone will tell you, assuming a contact is registered in your phone for your friend. The phone is using virtual markers in the communication stating that the phone number used for the interaction corresponds to your friend's number in your contacts. Notice that if your friend loses their phone or has it stolen from them, or if the phone was cloned, this method would trick you into thinking that the person you are talking with is someone else. This example illustrates the notions of identification and authentication, as well as the pitfalls. The identification is the phone number, and the authentication is adequate for most interactions in this case, because even if it has some flaws, it is generally recognized to be accurate. However, if the text message is urging you to transfer funds, or agree to a high value transaction, the identification method is no longer adequate.

Identities, roles, and privileges

Before we go further in the exploration of authentication schemes, let's look at what lies on the notion of adequate authentication. We saw in the previous module that privileges are granted based on the individuals, their attributes, and the roles that they embody. Before we can do this, we need to ascertain the identity of the subject first. The more privileges we will grant, the higher the level of confidence needs to be as to the identity of the subject. Inversely, we do not need a high level of confidence for publicly or almost publicly accessible objects. Therefore, the level of potential injury sustained for a wrong identification indicates the level of confidence required.

In this context, identification is the process of "claiming" an identity. The claim can be to a user ID, to a phone number, to an email address, etc. The notion of "authentication" is the confirmation that the claim is accurate. It seeks to provide credibility to the claim. Because of this, we refer to identifiers as "credentials".

Identity management and privacy

As you will recall from our study of repudiation and non-repudiation, there can advantages to an obscure identity and the use of untraceable pseudonym for our interactions. The use of authentication measures can be a threat to the privacy of the concerned individuals. For example, we would be correct to say that credit card transactions require a high level of confidence to the identity of the individual performing the transaction. However, this also means that a paper trail of credit card transactions will tie unrelated events together to an individual, revealing private and potentially sensitive activities.

Level of confidence of the identity claim

As we discussed, organizations must think about the potential injury for authentication errors to determine the level of confidence required. This will be part of a risk-based analysis of threats and injuries. Following the assessment, organizations then need to define a scheme of authentication: i.e., a method that will allow a subject to confirm their claimed identity in a satisfactory manner. There are many different schemes that can be put in place, relying on numerous different pieces of information. Organizations must consider security, of course, but also flexibility, reliability, cost, and complexity when selecting and implementing an authentication scheme.

In this section, we will discuss how to create an authentication scheme, and some of the more commonly used authentication schemes.

Authentication schemes

An authentication scheme is a method used to provide confirmation of the identity of the subject. Complete and absolute proof of the identity is never really guaranteed, this is why we call it a level of confidence. That level can be very high in some cases but is never certain beyond doubt.

The building block of an authentication scheme is called a factor of authentication. By combining factors into a specific process, we create an authentication scheme. Subjects must submit to the scheme successfully before they are recognized as such by the information system.

Authentication factor: something you know

The first and most common factor for information system is “something you know”. The factor is simple and easy to implement, at least in principle. The credibility to the identity is provided by asking the subject for an information that only the subject should know: a secret. Because it is not simple to know what should or not be considered a secret, it is common to make one for that purpose: i.e., a password. The password is in itself meaningless, it only serves to be a secret shared between the subject and the information system. Besides passwords, systems commonly using PIN codes, secret questions, and secret identifiers.

The strength of a secret as an authentication measure is predicated on the secrecy itself. For example, if the password is written down on a post-it, its secrecy might be compromised. If a subject uses the same password in many different circumstances, this could also jeopardize its secrecy. Even more, humans have a hard time remembering passwords and tend to opt for memorable ones. The problem is that it makes the password somewhat predictable. Passwords like “123456”, “qwerty”, and “iloveyou” are frequently used by unrelated individuals.

Authentication factor: something you have

Another factor that can attest for the identity of a subject is to prove the possession of an item, such as a token, that only the subject should have. These would include the ubiquitous symbol of security, the key. A key is an interesting token, seeing that its possession is a way to define your identity, or at least a level of privilege, but it is also part of a technical mechanism that restricts the access. The use of an item is an authentication factor known as “something you have”. In today’s virtual world, these tokens are becoming less tangible and more conceptual. For instance, if an information system wants to confirm your identity and sends you a PIN code over a text message to your phone number, what is the factor being used? In principle, it shows possession of the phone answering to that phone number, so it is a possession factor. However, someone eavesdropping over the communication network might see the value go by and use it, indicating that it is actually a secret being used. Let’s look at the example of a credit card. When using the “chip and PIN” method, this authentication method is using something you have. But, if the purchase is online, the use of the credit card becomes something you know: the card number, expiration date, and “card not present” verification number.

As you can see, it is sometimes ambiguous whether the factor is something you know or something you have.

Authentication factor: something you are

The third authentication factor is something you are. You might know this category as biometric authentication: the use of a biological marker to identify an individual. Markers include fingerprints, facial scan, voice recognition, palm scan, or any other “measures of life” which is the meaning of the word “biometric”.

Notice that biometric identification is how we recognize each other as humans: by our biological measurements. As indicated, machines are not yet very capable of conducting this identification but are fast becoming very adept at it. The following article provides an explanation of the three factors of authentication:

Supplemental factors

The three authenticator factors, something you know, something you have, and something you are, are the three potential components of an authentication scheme. This is because these factors are specifically linked to an identity. It is however possible to supplement the scheme by adding markers that, without identifying the subject, can add credibility to the claim of identity. Let’s better understand this concept by looking at some examples.

If your credit card is used in a shop in India, your credit card company might be suspicious of the transaction, especially if you used the card the same day in Ottawa. It is possible that the transaction is authenticated: the details of the card have all been provided, but the nature of the transaction is dubious.

Now image that your card is used in Ottawa, and this time the purchase is for five Rolex watches. Again, the transaction would likely be flagged as suspicious, that is unless you are in the habit of such purchases!

Supplemental markers are just that: they supplement the claim of identity. Common supplemental factors include geographical markers, and the nature and behaviour of the subject. If those markers are atypical, then the claim of identity might be challenged by the information system. This article define the three factors of authentication and provides some details of supplemental factors that can be used for schemes;

Bringing it all together

So, now that we know how authentication factors work, how do we bring it all together? As we mentioned before, the organization will need to consider several factors to determine a suitable authentication scheme. These factors include but are not limited to:

- Security level
- Cost of deployment
- Cost of maintenance
- Reliability
- Suitability for remote use
- Privacy concerns

With those factors in mind, the organization will agree on an authentication scheme that suits the business requirements.

One observation is that the characteristics of the types of factors will tend to be different. Secrets are vulnerable to eavesdropping. Tokens are susceptible to theft and duplication. Biometrics can be imitated. Secrets are cheap to deploy but cumbersome and a burden to users. Biometrics, on the other hand (pun intended), are costly and suffer from errors in measurement, as well as being privacy-invading. Tokens can be costly as well, and, like biometrics, less suitable for remote use.

This observation has brought experts to say that the combination of factors is an interesting way of building an authentication scheme. It is sometimes referred to as the “swiss cheese” analogy: when putting two slices against each other, the holes don’t align. In the same sense, by combining different factors they can mitigate each other’s weaknesses.

A true multifactor authentication scheme must leverage two factors from different categories. The use of a password and a PIN code is not a multifactor authentication in the strict sense. However, the “chip and PIN” authentication for a credit card transaction would be.

Authentication platforms

Today, there are many services that we use online that require us to authenticate. While it may seem transparent to us most of the time, there is a tremendous amount of work that goes on in the background. The security community is looking for ways to reduce the burden on providers without jeopardizing the security of operations, or the privacy of online users. This combination of requirements is not easy to tackle.

In this section, we look at current efforts to streamline and formalize authentication schemes and the characteristics of each of the strategies.

Localized solutions

Authentication needs to be performed at the device level very often. This process might be a lot more critical than we would assume. This is because once you authenticate to a device, like a smartphone, a lot of privileges and access are granted from that authentication. The assumption is that if you can access the device and unlock it, it is a solid claim to your identity. After all, it is a two-factor authentication scheme: you need the smartphone (something you have), and unless your phone is not locked, a PIN code, password, or biometric feature.

Many experts see the use of a smartphone as a logical scheme for authentication. Their use is very popular, we always have them handy, and their security is very good for the most part. Leveraging devices like laptops and smartphones, which are very personal devices and seldom shared nowadays, can yield the basis of a solid authentication scheme. After that, access to online accounts can use the authentication tokens stored on the device and provide fast and easy access to providers. A lot of our authentication schemes are based on this approach. The following article provides explanations on the use of personal devices for authentication purposes:

Centralized solutions

Another approach with rising popularity is to centralize the authentication scheme to a specialized service. This is sometimes referred to as a Federated Identity. Another way to describe it is authentication as a service, or AaaS. In this approach, a dedicated service holds the identity credentials of many users. Providers rely on the service to authenticate their users and do not perform an authentication process themselves. The AaaS vouches for the identity of the user by digitally signing an authentication token that the user presents to the provider. The following resource defines the use of a federated identity service:

Organizations like Google and Microsoft are setting themselves up to be providers of centralized authentication services for online providers. Facebook also provides this service. Proponents of the approach like the simplicity that it offers the providers who then are no longer required to implement their own authentication schemes. However, many security professionals fear that this centralization could have disastrous results if a breach occurs because the access to several online providers could be compromised at once. There are also concerns about the threats to privacy by having companies mostly known as data brokers being able to track logins of end-users to multiple online services.

Single-sign-on solutions

The use of a single-sign-on solution, or SSO, allows the centralization of authentication for a given domain, or realm. This is a solution for organizations that wish for their employees to be recognized at the organization level when they authenticate. The most commonly seen solution for this is Microsoft's Active Directory (AD). AD is a domain-level service that allows to define subjects, mainly users and devices, and grant them privileges. When users authenticate, this authentication is granted at the domain level, and users can then access objects defined in the domain without having to log in every time. Notice that concerns of privacy do not typically apply because this is an enterprise solution.

Cloud services

Cloud services do not rely on a specific authentication scheme. As is characteristic of cloud services, customers benefit from a variety of choices.

A cloud-deployed information system can use a custom-built authentication system that suits the business requirements. It can also use authentication services at the cloud provider level or some other form of centralized authentication service. Customers that deploy their infrastructure to the cloud can define domains using Azure's Active Directory services. Microsoft Azure's Active Directory is renamed to Entra ID as of October 2023. For more information on this change, read the following resource:

Authentication

Addressing issues in authentication schemes is a major challenges of today's cyber security community. Many different considerations must be assessed to devise authentication solutions that have flexible and user-friendly, yet robust and secure. The coming years will bring forth interesting solutions, potentially leveraging machine learning to identify anomalies in the use of online services.

Summary

Conclusion

In this module, we covered the quintessential access control: identification and authentication. This access control underpins the whole security implementation for identities, roles, access, and privileges. Threat actors routinely target authentication measures to thwart them and access information systems without authorization. Careful implementation of robust authentication schemes is essential for information systems today that are more exposed than ever before.

In the next module, we will look at the implementation of incident handling capabilities for organizations.

References

The references listed here, coupled with the course developer's experience, have been used in the development of this module:

n.a. (n.d.) How is a Cell Phone Used for Login Authentication? Prox Devices. Retrieved from https://www.proxdevices.com/post/how-is-a-cell-phone-used-for-login-authentication

n.a. (2011). Understanding the Three Factors of Authentication. Pearson IT Certification. Retrieved from https://www.pearsonitcertification.com/articles/article.aspx?p=1718488

n.a. (2023). Azure Active Directory is now Microsoft Entra ID. Microsoft. Retrieved from https://www.microsoft.com/en-us/security/business/identity-access/microsoft-entra-id

n.a. (2023). What Is Federated Identity? Okta. Retrieved from https://www.okta.com/identity-101/what-is-federated-identity/

Donegan, Katie (2019). 5 common authentication factors to know. TechTarget. Retrieved from https://www.techtarget.com/searchsecurity/feature/5-common-authentication-factors-to-know

Module 12 | Incident handling and resilience

Incident handling prepares an organization to detect, analyze, contain, recover from, and learn from security events. The module connects prevention, layered defense, cyber resilience, and the phases of a formal incident response process.

Introduction

Incident handling is a subset of cyber security activities. Every organization must enable a defensive posture, but also be ready for the eventuality of a cyber attack breaching those defences. When talking about cyber breaches, it may be more accurate of saying it is more a matter of “when” than “if”. In this module, we will cover the basic concepts surrounding incident management and recovery.

Learning Objectives

By the end of this module, you should be able to complete the following:

1. Recall the phases of an incident handling plan.
2. Situate incident handling in a broader cyber security context.

Key Terms and Concepts

Defence-in-depth — Defence-in-depth is a concept used in information security in which multiple layers of security controls (defense) are placed throughout an information technology (IT) system. Its intent is to provide redundancy in the event a security control fails, or a vulnerability is exploited that can cover aspects of personnel, procedural, technical and physical security for the duration of the system's life cycle.

Holistic — A holistic approach is characterized by the belief that the parts of something are interconnected and can be explained only by reference to the whole. In cyber security, a holistic approach seeks to interconnect personnel security, network security, application security, and other security considerations to make them work together instead of piece by piece.

Red herring — A red herring is something that misleads or distracts from a relevant or important question. In cyber security, it is a reference to an attack that is meant to draw attention and leave other parts of the infrastructure less protected and vulnerable to compromise.

Incident handling and cyber resilience

For many weeks, we have been discussing matters of security in the digital realm. We analyzed notions of confidentiality, integrity, and availability. We defined the needs for repudiation and nonrepudiation. We saw how organizations can use labels on documents and systems to convey their sensitivity to stakeholders. And recently, we analyzed how security controls and access controls can be used to implement a strategy to grant or deny access to subjects wanting to interact with organizational resources and assets. You could think that with all of this, organizations would be well protected against any unauthorized activity, but that would be wishful thinking.

Of course, it could be argued that not all organizations manage to put all these security measures in place. Would an organization that does be protected against compromise? This is what we will examine in this module.

Prevention is not sufficient

Unfortunately, we must concede that prevention, though necessary it might be, will not be a guarantee against compromise. Many security experts view prevention efforts as turning the organization into a “hard target”. This means that if an attacker wishes to breach the organization, they will need to invest more time, money, expertise, and risk into the operation. They might still pull it off, but it will be at a higher cost. The goal is to build resilience against attacks.

Attackers are motivated by several different factors, financial gain being the most common one. In that perspective, attackers would select targets for their susceptibility to compromise. Hard targets, costlier and riskier to compromise, are likely to be passed over in favour of easier ones. It would make sense to behave as such for attackers trying to maximize their profit.

Another consideration is that compromises have a tendency to spread and impact other organizations. For example, imagine an attacker breaches Organization A because of an unpatched vulnerability. Once inside, the cybercriminal steals intellectual property, other data, and user credentials. Typically, the attack will involve deploying ransomware, putting the organization into a difficult position of paying the ransom or starting a long recovery process. What happens after that? Well, if the attacker manages to crack the stolen credentials, it might yield usable credentials to other systems that the users are also part of. Users tend to reuse passwords and cybercriminals know this. Also, the cybercriminal might steal security configuration details from the organization

and be able to compromise it again later. He might put a backdoor into the system and sell it to another criminal organization. If Organization A pays the ransom, usually several millions of dollars, part of that money will be reinvested into building better cyber weaponry to attack other organizations, including the attack infrastructure for deployment, talent recruiting, and even using artificial intelligence for weapon development. The following article provides details about the cyber weapon market, including weaponry used by cybercriminals:

The role of cyber security controls for incident handling

Because there are sustained levels of attacks against online systems, any vulnerability is likely to be discovered and exploited by threat actors. Attackers are using automated tools to systematically probe, identify, and exploit any opportunity to breach online targets. Therefore, deploying an efficient range of cyber security controls, as we explored throughout the course, is essential to offset the risk of a cyber attack.

In this module, we will explore additional considerations for cyber security controls in the optic that preventive measures can be breached despite our best efforts.

Incident readiness strategies

To get started in the discussion on incident handling, we will explore some of the strategies used to deploy a more complete approach to eventual breaches. Two popular approaches are:

- Holistic security
- Defence-in-depth / layered defence
- PDARR security layering

Holistic approach

As we discussed in previous modules, security is not well served by a “check mark” approach. Security should instead be approached as a holistic process, where the global picture matters more than the individual application of security controls. The building blocks of a holistic approach have already been studied:

- Establishing roles and responsibilities at the organizational level.
- Assess organizational risks based on asset sensitivity.
- Establish and enforce security policies to address the perceived risk.
- Monitor and react to security issues.

This last item is what we are discussed in this current module.

Defence-in-depth / layered defence

A defence-in-depth approach means that we work to avoid a situation known as a single-point-of-failure. That situation means that a component is critical to a general process, and if that component fails, the whole process goes down. This can be seen in a security context, where a security control is intrinsic to the entire security posture, leaving the organization unprotected if it goes down.

Security experts recommend layering security controls to create multiple barriers to a would-be attacker. Traditional approaches more commonly used a perimeter-based defence, investing all the security resources in a hard protective shell, but leaving the organization wide open if the perimeter is breached. A layered defence approach forces the attacker to successively breach multiple security controls, one after the other, before a compromise is accomplished.

PDARR security controls

The acronym PDARR stands for Prevent-Detect-Analyze-Respond-Recover. It works with a layered defence by defining and placing security control beyond the preventive barrier. Security controls will also allow for the detection of threats and potential compromise, the capacity to analyze the breach, contain the compromise, and engage into recovery measures. Security controls are needed along the whole sequence of events concerning security breaches.

The PDARR approach illustrates how incident handling typically plays out. Preventive measures are put in place, but with the acknowledgement that breaches can still happen.

Incident handling phases

Most security experts agree that an incident handling plan should be laid out in phases. Different plans use different phases, but the essence of the plan will usually a similar breakdown. In this section, we will analyse an incident handling breakdown acccording to a five-phase plan. You can consult the source of the information here:

There is not a unique “right” way to devise an incident handling plan. Experts agree that any investment into increasing the cyber resilience of the organization through an incident handling plan will be worthwhile.

Let’s look at the breakdown of a typical incident handling plan. The goal for such a plan is that organizations will use it as a blueprint to create their own implementation of incident handling activities.

Phase 1: Preparation

The first step, logically enough, is preparing for incidents. This is undoubtedly the most important phase for many reasons. First of all, it is the acknowledgement by the organization that incidents are likely to happen despite their best efforts. There’s a popular saying in cyber security stating that: “There are two types of organizations: the ones that have been breached, and the ones that have been breached but don’t know it yet”. This joke highlights the reality that security incidents will happen, and we must accept the fact and prepare accordingly.

Obviously, the preparation phase will follow with cyber security measures. Policies, directives, and procedures will be required to transmit the information to relevant stakeholders. Roles and responsibilities will be agreed upon, defined, and put into writing. Other typical activities that occur at this phase include:

- Creating a complete inventory of organizational assets that includes their assessed sensitivity level.
- Defining an incident handling unit that will take charge in case of a compromise.
- Creating a communication plan that defines how communication will take place, who to communicate information to, and what information needs to be transmitted during the incident handling.
- Provide awareness and training to all relevant individuals involved in incident management.
- Incorporate “lessons learned” report into the incident handling procedures. More on that later in the “Post-activity phase”.
- Deploying and maintaining cyber security controls to protect the infrastructure and monitor for cyber security events.

The preparation phase is considered the most critical aspect of incident handling and is also the most time-consuming one. Some estimates place the amount of effort allocated to the preparation phase at 90% of the overall incident handling effort. Preparation enables the other phases and is key to mitigating the impact of potential incidents.

Phase 2: Detection and reporting

With the infrastructure prepared and everybody knowledgeable about their roles and responsibilities, detection mechanisms will allow cyber operators to monitor the network activities. Early detection has been observed to be the key to minimizing the damage from breaches and incidents. The cost of a cyber breach can be correlated to the time required to detect the breach and react to it. This is because the longer an intruder is allowed to remain unimpeded within the organization’s perimeter, the more damage that attacker can cause. The longer it takes to identify and contain the breach, the costlier it becomes because the damage is going to be more widespread.

Detection tools include logging and monitoring of all events occurring in the network. However, that will not be enough. Many times, organizations log events and do not realize that the events are pointing to signs of intrusion because they are not actively looking for those signs. Active monitoring of log information is required for efficient detection. To achieve this, operators rely on dashboards, triggers, and automated analysis, sometimes enhanced by machine learning algorithms to detect in near real-time that an attack is unfolding. It can make a tremendous difference in the efficiency of incident handling activities.

Phase 3: Triage and analysis

In this phase, the role of operators is to be able to quickly and efficiently determine whether the events detected as potential compromises are indeed an attack. If so, they must determine as much information as possible about the breach to enable the next phase of incident handling. Because organizations want to make sure that no attack goes through unnoticed, the thresholds that will trigger alarms will err towards caution. That means that the alarms might result in many false positives, i.e., the systems detect what could be signs of intrusion but turns to be legitimate activity in the network. This is necessary to reduce the number of false negatives, i.e., events that are seen as benign but are in fact malicious events indicative of an attack.

Over time, systems can be better calibrated to reduce false positives while maintaining false negatives at a very low level. However, because systems evolve, and levels of online activity can be sporadic and unpredictable, false positives will be unavoidable.

Phase 4: Containment and neutralization

At this point, malicious events were detected and analyzed to be indicative of a breach or compromise to the organization's infrastructure. In other words, this phase is where the incident handling per se occurs. The goal in this phase is to keep the incident from spreading, i.e., contain the damage, so that the intrusion can be neutralized and eradicated from the systems.

There are many ways that an incident can be contained:

- Disconnect contaminated devices from the network.
- Shut down and disable compromised user accounts.
- Revoke privileges from suspected subjects involved in the incident.

In some cases, the incident is a distraction purposely deployed against the organization to draw resources in one direction while the actual compromise is occurring against other parts of the network. Incident handlers must be careful to maintain a heightened level of alert while dealing with the incident and for a while afterwards in case the incident was a red herring.

Phase 5: Post-incident activity

An often disregarded but very importance phase is the post-incident analysis, sometimes referred to as the incident post-mortem. In this phase, the incident has been handled and the organization analyzes their performance, looking for ways to improve on their incident handling capabilities.

Some questions will drive the discussion in this phase, namely:

- What vulnerabilities were exploited that allowed the incident to occur?
- What have we done to reduce the probability of such an incident from reoccurring?
- What have we done to minimize the damage that would be suffered if this incident happens again?

To be clear, the goal of this phase should never be about blame. It is conducted in the spirit of continuous improvement and building resilience. The organization should use this phase to identify and implement enhancements to all the phases of incident handling, so that they emerge from the incident stronger than before. Decisions made in this phase are actioned in the preparation phase and the cycle continues.

This concludes a high-level overview of incident handling activities, broken down in five phases. Incident management is now recognized as its own branch of cyber security, with highly specialized training available in this field.

Some such training includes the EC-Council Certified Incident Handler program. Details about the training are available here:

However, incident handling is not just for the experts. Any user of a system has a responsibility towards incident handling. This includes:

- Implementing cyber security controls that are under their responsibility, and never circumventing security controls that have been put in place.
- Complying with applicable security policies as defined by the organization.
- Reporting any anomalies in the system as soon as possible, to enable quick response from defenders.
- Report potential compromises from clicking on links or opening attachments as soon as possible.

Incident handling is a critical and essential part of cyber security, but it is also more than that. The same preparation for malicious cyber attacks can enable organizational resilience against hardware failures and other events that are detrimental to operational performance.

Summary

Conclusion

Summary In this module, we covered the basics of defining and implementing a cyber security incident management plan. We looked at the considerations that go into devising and introducing the plan, and how incident handling complements preventive cyber security.

In the next and final module, you will examine the implications of cloud computing for the current and future state of cyber security.

References

The references listed here, coupled with the course developer's experience, have been used in the development of this module:

n.a. (2023). The Ultimate Guide To Incident Management. Resolver. Retrieved from https://www.resolver.com/resource/the-ultimate-guide-to-incident-management/

Bandos, Tim (2023). The Five Steps of Incident Response. Digital Guardian. Retrieved from https://www.digitalguardian.com/blog/five-steps-incident-response

Byerley, Steven (2023). Global cyber weapon market set for significant growth. Insurance Business. Retrieved from https://www.insurancebusinessmag.com/ca/news/cyber/global-cyber-weapon-market-set-for-significant-growth-458408.aspx

Vicente, Vice (2023). NIST Incident Response: Your Go-To Guide to Handling Cybersecurity Incidents. AuditBoard. Retrieved from https://www.auditboard.com/blog/nist-incident-response/

Module 13 | Cloud security outlook

Cloud security keeps changing as skills, architectures, and threats evolve. The module discusses skills shortages, zero trust, data residency, artificial intelligence, and the integration of security into DevSecOps.

Introduction

It is well known that cyber security is a major concern today for individuals, private sector companies, large multinationals, governments, and countries. In this closing module, we will discuss expert opinions about trends, predictions, and the evolving landscape and cyber security and cloud computing security.

Learning Objectives

By the end of this module, you should be able to complete the following:

1. Recall trends and emerging concerns in the world of cyber security.
2. Recall up-and-coming solutions for cloud security that will be in place in the coming years.

Key Terms and Concepts

Zero trust security model — The zero trust security model, also known as zero trust architecture (ZTA), and sometimes known as perimeterless security, describes an approach to the strategy, design and implementation of IT systems. The main concept behind the zero trust security model is "never trust, always verify," which means that users and devices should not be trusted by default, even if they are connected to a permissioned network such as a corporate LAN and even if they were previously verified. ZTA is implemented by establishing strong identity verification, validating device compliance prior to granting access, and ensuring least privilege access to only explicitly authorized resources. Most modern corporate networks consist of many interconnected zones, cloud services and infrastructure, connections to remote and mobile environments, and connections to non-conventional IT, such as IoT devices. The reasoning for zero trust is that the traditional approach — trusting users and devices within a notional "corporate perimeter", or users and devices connected via a VPN — is not relevant in the complex environment of a corporate network. The zero trust approach advocates mutual authentication, including checking the identity and integrity of users and devices without respect to location, and providing access to applications and services based on the confidence of user and device identity and device health in combination with user authentication. The zero trust architecture has been proposed for use in specific areas such as supply chains.

Forward outlook

It can be very useful to have a forward-facing outlook on the trends in cyber security and its evolving status. It helps us to define our priorities and to remain ahead of the changes. Every year, experts provide us with their take on the current trends and offer predictions for the coming year. In this module, we will look at some of the reports and blog posts that were published in 2023 about the cyber and cloud security.

Cyber security skills shortage

Bernard Marr, a contributor of Forbes magazine, talks about the biggest security trends for 2024 in the following article:

In the article, the author discusses what he refers to as “the cyber security skills crunch”. This is in relation to the shortage of experts in the cyber security field that has been problematic for several years. Marr expects that this will continue to be an issue in 2024, and that more investment will be poured into creating the cyber professionals of tomorrow.

Zero-trust

Among the predictions of many experts in the field is the belief that zero- trust, a new paradigm in security, will become much more broadly implemented in organizations. Zero-trust is a conceptual approach that is defined by the removal of the perimeter as a protective barrier. Since high reliance on a working-from-home setup and the outsourcing of IT infrastructure to cloud became the norm, the perimeter pretty much ceased to exist as a barrier between “us” and “them”. A zero-trust approach states that no subject, object, or communication is implicitly trusted (something that would have been the case within a perimeter), but rather everything interaction must be authenticated and validated before it is allowed to proceed.

According to Gartner in a March 2023 press release, they predict that 10% of large enterprises will have a comprehensive zero-trust program in place by 2026:

Global data storage

Cybercrime Magazine Editor-in-Chief, Steve Morgan, predicts that by 2025, the world will need to cyber protect 200 zettabytes of data, stored in data centres and devices around the world. If you’re not familiar with the zettabyte unit of measurement (and who is, really) here is the definition from Wikipedia:

“A zettabyte is a digital unit of measurement. One zettabyte is equal to one sextillion bytes or 1021 (1,000,000,000,000,000,000,000) bytes, or, one zettabyte is equal to a trillion gigabytes. To put this into perspective, consider that if each terabyte in a zettabyte were a kilometre, it would be equivalent to 1,300 round trips to the moon and back (768,800 kilometers). As former Google CEO Eric Schmidt puts it, from the very beginning of humanity to the year 2003, an estimated 5 exabytes of information was created, which corresponds to 0.5% of a zettabyte. In 2013, that amount of information (5 exabytes) took only two days to create, and that pace is continuously growing.”

The same article predicts that half of this staggering amount of data will be stored in the cloud, up from about 25% in 2015.

The article from Cybercrime Magazine also predicts that 90% of the human population aged 6 years and older will be online by 2030, leading to a rise in cybercrime:

Artificial intelligence and machine learning

Unsurprisingly, artificial intelligence and machine learning appear in several lists about upcoming concerns in the field of cyber security. Part of the concern is that experts do not know yet if AI will be more of a threat or a cyber defense tool. The answer likely falls in between. AI is already actively used by cyber attackers to devise cyber weapons, write phishing emails, and evade cyber defences. Unless cyber security experts harness the power of AI for defensive measures, the attackers will gain the upper hand. On top of that, experts in other fields worry about the weaponization of AI and its eventual use for military operations.

The following blog post discusses several trends and predictions concerning cloud security. Read about them here:

Security integration into DevSecOps

According to many experts, DevSecOps will continue to rise, and cloud-native applications will become more and more popular in the coming years. It is also expected that employees will start to build more and more of their own code without referring to the IT department, an approach known as “citizen development”.

Even though it was initially eyed with suspicion by security experts when it was first introduced, agile development and DevOps has proven to be a worthwhile replacement to the old and clunky software development lifecycle approaches of the past. DevSecOps integrates several security activities in the development pipeline and shows great promise to fix some of the security issues plaguing application development today.

The following blog post discusses the ever-evolving landscape of cloud security trends. It brings interesting points about cloud security and DevSecOps:

Future of cloud

There aren’t any experts out there predicting that the use of cloud will go down, and that IT will be returning to on-premises deployments. The use of cloud and accompanying technologies such as DevSecOps will keep rising in coming years. Of course, no one can really predict the future, but it is a safe bet that working from home with distributed infrastructures powered by cloud

technologies will be there for years to come.

Summary

Conclusion

In this module, we concluded our study of security concepts in the context of cloud and DevSecOps.

References

The references listed here, coupled with the course developer's experience, have been used in the development of this module:

n.a. (2023). The ever-evolving landscape of cloud security trends. NordLayer. Retrieved from https://nordlayer.com/blog/cloud-security-trends/

Keen, Emma (2023). Gartner Unveils Top Eight Cybersecurity Predictions for 2023-2024. Gartner. Retrieved from https://www.gartner.com/en/newsroom/press-releases/2023-03-28-gartner-unveils-top-8-cybersecurity-predictions-for-2023-2024

Marr, Bernard (2023). The 10 Biggest Cyber Security Trends In 2024 Everyone Must Be Ready For Now. Forbes. Retrieved from https://www.forbes.com/sites/bernardmarr/2023/10/11/the-10-biggest-cyber-security-trends-in-2024-everyone-must-be-ready-for-now/?sh=3e12580d5f13

Morgan, Steve (2023). Top 10 Cybersecurity Predictions and Statistics For 2023. Cybersecurity Ventures. Retrieved from https://cybersecurityventures.com/top-5-cybersecurity-facts-figures-predictions-and-statistics-for-2021-to-2025/

Stephens, Luke (2023). 5 Cloud Security Predictions for 2023. Wiz Blog. Retrieved from https://www.wiz.io/blog/5-cloud-security-predictions-for-2023

Module 14 | Final exam

The course contents list only the final exam for Module 14. No separate study-note page is available there, and the exam is excluded as requested.